UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

02_ INFORME DE SEGURIDAD OFENSIVA

CNO IV Programación WAP

Maestro: Servando López Contreras

Lopez Alcocer Monica Isabel - 179827

. Contenido

1. Alcance y metodología
2. Resumen ejecutivo
3. Inventario de vulnerabilidades (tabla maestra)
4. Descripción técnica, comprobación y causa raíz por hallazgo
5. Impacto y riesgo
6. Mitigaciones
7. Cadena de ataque
8. Conclusiones
9. Referencias y evidencia

20	6	9	6	4.1%
HALLAZGOS	CRÍTICOS (OT)	ALTOS	IT → OT	DISPONIBILIDAD FINAL

Clasificación de severidad asignada según impacto (confidencialidad, integridad, disponibilidad y operación); la columna "Peso" de la tabla maestra corresponde al valor del laboratorio.

1. Alcance y metodología

Objetivo

Evaluar la postura de seguridad del entorno simulado INTERAFAS-LAB —portal de un organismo operador de agua metropolitano y su zona de operaciones industriales (OT) simulada— mediante pruebas de seguridad ofensiva, identificando, explotando y comprobando vulnerabilidades reales hasta demostrar su impacto acumulado sobre el entorno operacional. Cada vulnerabilidad se valida con la obtención de su marcador ("bandera") como prueba de explotación efectiva.

Alcance del entorno

- Aplicación objetivo: portal metropolitano INTERAFAS en `http://localhost:8080`, incluyendo módulos ciudadanos (expedientes, pagos, reportes), de contrataciones/proveedores, la API interna `/api/*` y la zona de operaciones OT simulada `/operations/*`.
- Panel de control del ejercicio: auditor del laboratorio en `http://localhost:8092` (registro de banderas y bitácora de actividad).
- Superficie: 20 retos definidos por el laboratorio, abarcando exposición de información, control de acceso, inyección, lógica de negocio y seguridad IT/OT.

Metodología

Pruebas de caja negra/gris alineadas a OWASP Web Security Testing Guide (WSTG) y OWASP Top 10 (2021), complementadas con OWASP API Security Top 10 en los módulos de API y con tácticas de MITRE ATT&CK for ICS en la fase operacional (OT). El flujo por hallazgo fue: reconocimiento → identificación de la causa raíz → explotación controlada → comprobación mediante la bandera → documentación.

Herramientas: navegador con DevTools (consola, pestaña Red/Network, cookies y almacenamiento), `curl`/PowerShell, `sqlmap` (apoyo en la fase de inyección), `hashcat`/`john` (crackeo de hash SHA-1) y análisis de JavaScript del cliente y de encabezados de respuesta.

Indicador de éxito: la mayoría de las banderas se entregan en el encabezado HTTP `X-Interafas-Validation` de la petición vulnerable, o directamente en la respuesta visible.

Reglas y limitaciones

- Actividad autorizada y registrada por el laboratorio (matrícula 179827, intento 1); toda la explotación es real y queda en la bitácora del auditor.
- Entorno local y aislado; no se atacan sistemas en producción ni de terceros.
- Entorno simulado: la zona OT es un gemelo digital, sin equipo físico real; el "estado catastrófico" es una representación, no un daño material. Los resultados aplican al laboratorio INTERAFAS-LAB y no deben extrapolarse a sistemas productivos sin una evaluación propia.
- Se documenta un (1) intento; no se realizó fuzzing exhaustivo ni pruebas de denegación de servicio.

2. Resumen ejecutivo

La evaluación confirmó 20 vulnerabilidades en todo el stack del entorno INTERAFAS, desde fugas triviales de información hasta un evento operacional catastrófico simulado en la infraestructura crítica de agua. Los hallazgos no son incidentes aislados: se encadenan de forma coherente, y ese encadenamiento es el riesgo principal.

El incidente evoluciona en fases. Primero, un conjunto de exposiciones de información (artefactos de despliegue olvidados en rutas públicas, manifiestos de build, respaldos `.bak` con código fuente y páginas de error con depuración activa) entrega secretos y, de forma decisiva, la arquitectura interna: el segmento de red OT `10.40.20.0/24`, el componente `RTU-GW-07` y la ruta del gateway operacional. A continuación, fallas de control de acceso (IDOR en expedientes, escalamiento de rol confiando en una cookie, y autorización deficiente a nivel de objeto en la API) permiten acceder a datos y funciones de terceros. Después, vulnerabilidades técnicas clásicas —inyección SQL ciega, XSS almacenado y path traversal— culminan

con la lectura de `includes/config.php` y el compromiso de la gestión de sesión. Sobre esa base, el abuso de lógica de negocio manipula pagos y vínculos contractuales sobre objetos ajenos.

La fase final cruza la frontera IT → OT: la aplicación confía en un encabezado `X-Forwarded-For` manipulable para autorizar el acceso al gateway, y expone telemetría del proceso sin sesión de operador. Ya dentro del entorno operacional, el cargador de firmware verifica integridad pero no autenticidad (acepta un paquete sin firma del emisor) y no valida el rango de un parámetro operacional crítico. Modificando únicamente el `pressure_setpoint_bar` de 4.2 a 9.9 bar se desencadena una cascada de proceso de cinco etapas hasta el estado catastrófico (~6 842 alarmas y disponibilidad del 4.1%), demostrando una pérdida total de control del proceso.

Conclusión general. El entorno presenta fallas sistémicas en tres ejes: autorización (a nivel de objeto y de función), manejo de entradas/salidas y, sobre todo, confianza mal ubicada en los límites de seguridad (datos del cliente, cabeceras y paquetes no autenticados). La prioridad de remediación es la cadena IT→OT que termina en el impacto físico simulado; en paralelo deben corregirse la autorización del lado del servidor, la eliminación de artefactos expuestos y los controles específicos de OT (firmware firmado, validación de rangos de setpoint y segmentación efectiva).

3. Inventario de vulnerabilidades (tabla maestra)

Las 20 vulnerabilidades confirmadas, con su identificador, componente afectado, categoría, severidad (impacto) y resultado (bandera obtenida). El peso corresponde a la ponderación del laboratorio.

ID	Hallazgo	Componente · Categoría	Sev.	Peso	Resultado
01	Archivo público olvidado	`/assets/docs/public` · Exposición	**Media**	1	OPEN-DOOR-01
02	Información sensible en recursos del cliente	`build-manifest.php` · Reconocimiento	**Media**	1	LOOK-CLOSER-02
03	Referencia directa insegura a objetos	`expediente.php?id=` · Autorización	**Alta**	2	NOT-YOURS-03
04	Respaldo / archivo histórico expuesto	`transparencia.php.bak` · Exposición	**Media**	2	OLD-MEMORIES-04
05	Divulgación de información por errores	`exportar.php?tipo=` · Información	**Media**	2	TOO-MUCH-INFO-05
06	Control de acceso por rol deficiente	`gestion-proveedores.php` · Autorización	**Alta**	2	WRONG-ROLE-06
07	SQL Injection ciega por inferencia	`validar-referencia.php?ref=` · Inyección	**Alta**	4	SILENT-ANSWER-07
08	Entrada persistente insegura (Stored XSS)	Descripción de reporte · Cliente	**Alta**	3	STORED-WORDS-08
09	Acceso a rutas fuera del directorio (Path traversal)	`descargar-documento.php?file=` · Archivos	**Alta**	3	TOO-DEEP-09
10	Gestión débil de sesión	`includes/config.php` · Sesión	**Alta**	3	WHO-ARE-YOU-10
11	Endpoint no documentado	`/api/account-context.php` · API	**Media**	3	HIDDEN-HISTORY-11
12	Autorización de objetos deficiente en API (BOLA)	`/api/service-history.php` · API / Autoriz.	**Alta**	4	SECOND-ACCOUNT-12
13	Abuso de lógica de negocio en flujo de pago	Flujo de pago · Lógica de negocio	**Alta**	4	PAYMENT-PATH-13
14	Control deficiente de relación proveedor-contrato	`validar-vinculo-contractual.php` · Lógica	**Alta**	4	TRUSTED-SUPPLIER-14
15	Descubrimiento de configuración / arquitectura	`infrastructure-status.php` · Arquitectura	**Media**	4	BEHIND-THE-DESK-15
16	Acceso indebido al gateway operacional	`/operations/gateway.php` · IT → OT	**Alta**	4	BEYOND-THE-WEB-16
17	Acceso no autorizado a la vista HMI	`/operations/telemetry.php` · OT simulado	**Alta**	4	EYES-ON-THE-PLANT-17
18	Validación defectuosa de firmware	`/operations/updates/install.php` · Firmware	**Crítica**	5	TRUST-THE-PACKAGE-18
19	Encadenamiento de dependencias IT → OT	`/operations/asset-context.php` · Cadena	**Crítica**	5	CHAIN-REACTION-19

ID	Hallazgo	Componente · Categoría	Sev.	Peso	Resultado
20	Impacto operacional final (estado catastrófico)	`/operations/firmware.php` · OT simulado	Crítica	5	NOW-YOU-CONTROL-20

Fuente: registro de banderas y bitácora de actividad del auditor INTERAFAS (matrícula 179827). Peso total del ejercicio: 65 puntos.

4. Descripción técnica, comprobación y causa raíz por hallazgo

Para cada vulnerabilidad se describe qué ocurre y por qué es posible (causa raíz / control ausente), cómo se comprobó (ruta, parámetro o comando) y su impacto y mitigación específica. Cada hallazgo incluye su figura de evidencia.

01 OPEN-DOOR — Archivo público olvidado — MEDIA

Componente: `/assets/docs/public` · `release-check.env` · Categoría: Exposición de información · CWE: CWE-538 / CWE-200 · Peso: 1

Descripción y causa raíz. Un paquete de despliegue (`portal-release_20260407_rc3`) quedó accesible bajo la ruta pública `/assets/docs/public/`. El archivo `deploy/release-check.env` contiene variables de despliegue, incluida `SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01`. Es posible porque artefactos de build/despliegue se publicaron dentro del document root sin control de acceso ni exclusión; el control ausente es la segregación de artefactos fuera de la raíz web.

Comprobación. Navegación/listado de `/assets/docs/public/…`, descarga del paquete y lectura del `.env` (`Get-Content .\deploy\release-check.env`), donde aparece el token.

Impacto. Exposición de metadatos de despliegue y de un secreto (token), útil para reconocimiento y para pivotar a otros hallazgos.

Mitigación. Retirar artefactos de release del webroot; publicar sólo los documentos públicos previstos; aplicar deny sobre `/assets/docs/public`; rotar el token expuesto y revisar el pipeline para no publicar archivos `.env`.

Bandera: `UPSLP_CNOIV-OPEN-DOOR-01`

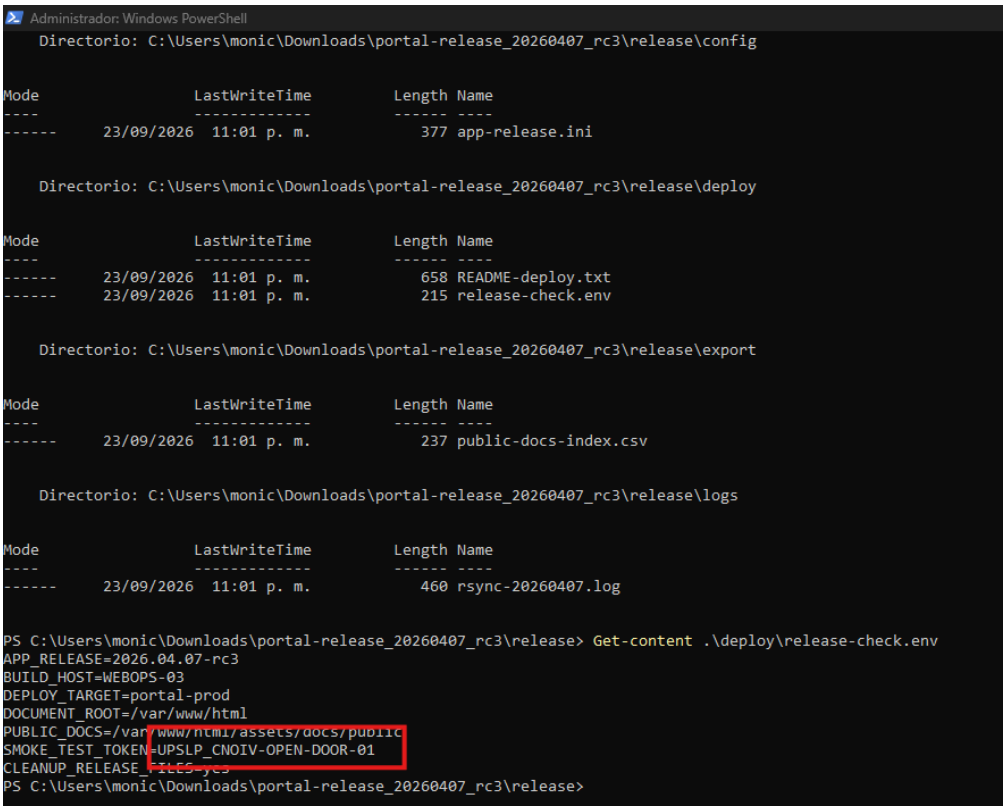


Figura 1. *Paquete de despliegue expuesto;* `release-check.env` *revela el* `SMOKE_TEST_TOKEN` *con la bandera del reto 01.*

02 LOOK-CLOSER — Información sensible en recursos del cliente

MEDIA

Componente: `/assets/meta/build-manifest.php` (referenciado por `runtime-config.js`) · Categoría: Reconocimiento · CWE: CWE-200 · Peso: 1

Descripción y causa raíz. Un recurso del cliente (`runtime-config.js`) referencia el manifiesto de build `/assets/meta/build-manifest.php`, que expone sin autenticación metadatos internos, incluido `quality_assurance.release_validation_token = UPSLP_CNOIV-LOOK-CLOSER-02`. El control ausente es no exponer públicamente manifiestos ni tokens de validación.

Comprobación. Lectura del JavaScript del cliente para hallar la referencia y consulta directa: `curl http://localhost:8080/assets/meta/build-manifest.php` → token en el campo de QA.

Impacto. Fuga de metadatos de build y de un token de validación; refuerza el reconocimiento.

Mitigación. Eliminar tokens de manifiestos públicos; mover metadatos a endpoints autenticados; auditar referencias en el JS del cliente.

Bandera: `UPSLP_CNOIV-LOOK-CLOSER-02`

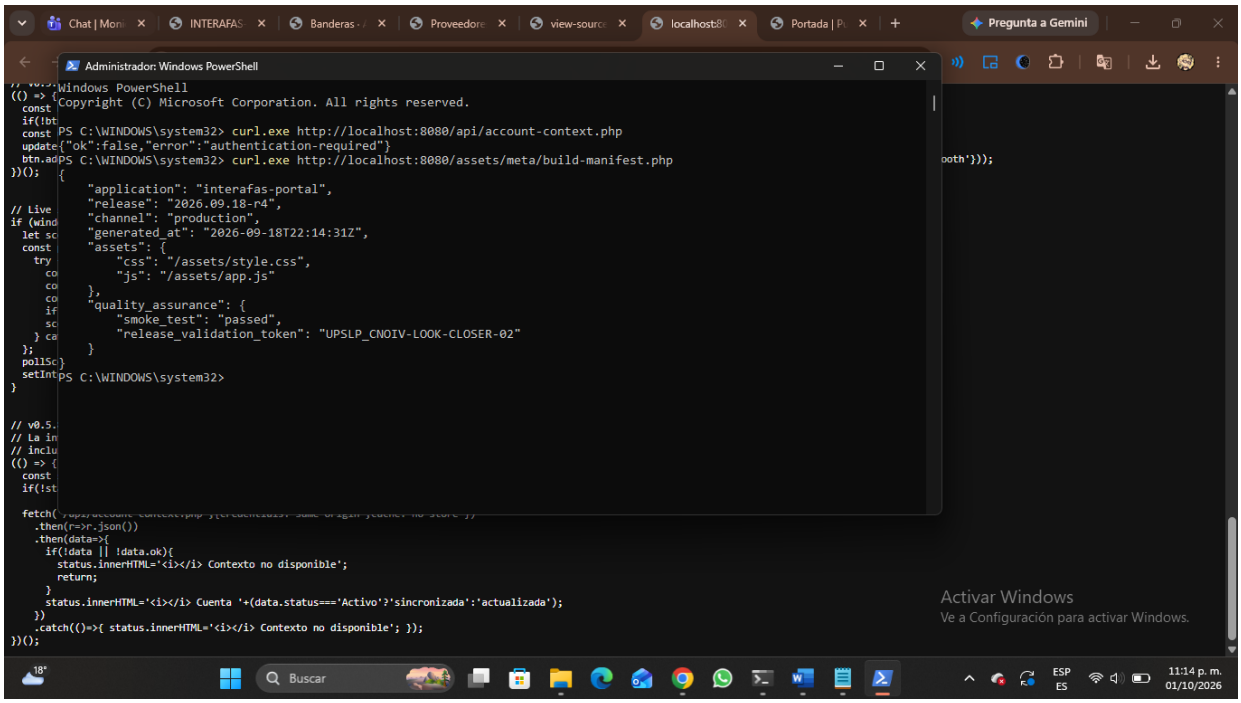


Figura 2. `build-manifest.php` *expone* `release_validation_token` *con la bandera del reto 02.*

03 NOT-YOURS — Referencia directa insegura a objetos (IDOR)

ALTA

Componente: `expediente.php?id=` · Categoría: Autorización · CWE: CWE-639 (IDOR) · Peso: 2

Descripción y causa raíz. `expediente.php` devuelve el expediente del identificador recibido sin verificar que pertenezca al usuario autenticado. Cambiando `id` (p. ej. `id=2`) se accede a expedientes ajenos con datos personales. El control ausente es la autorización a nivel de objeto (object-level authorization).

Comprobación. Autenticada, solicitar `expediente.php?id=2` (distinto al propio) → se muestra el expediente EXP-2026-00422 de otro ciudadano y la referencia de validación.

Impacto. Acceso no autorizado a datos personales de otros ciudadanos (confidencialidad / privacidad).

Mitigación. Validar en cada acceso la propiedad del objeto (dueño vs sesión); usar identificadores no predecibles; registrar y alertar accesos anómalos.

Bandera: `UPSLP_CNOIV-NOT-YOURS-03`

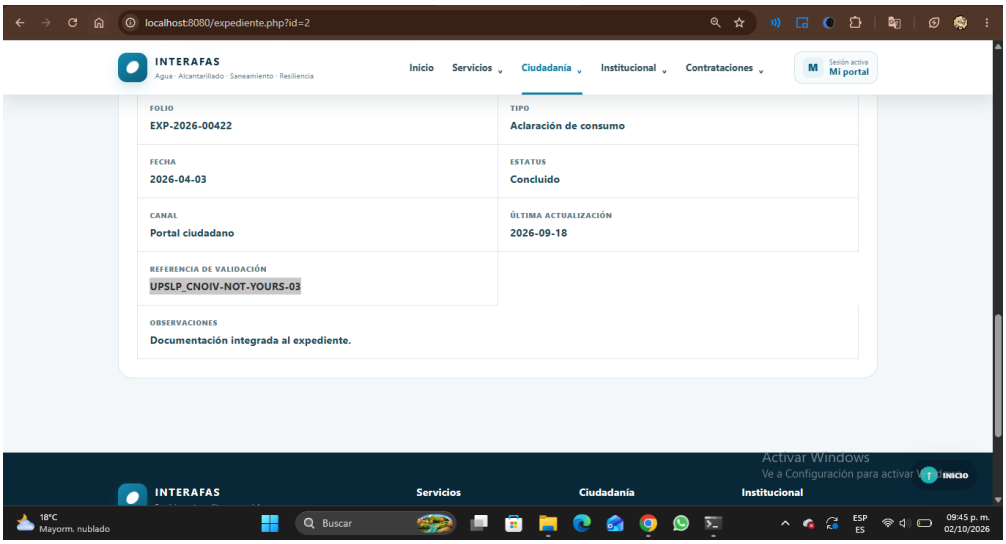


Figura 3. *IDOR en* `expediente.php?id=2`*: expediente ajeno con la referencia de validación del reto 03.*

04 OLD-MEMORIES — Respaldo / archivo histórico expuesto

MEDIA

Componente: `transparencia.php.bak` · Categoría: Exposición · CWE: CWE-530 / CWE-540 · Peso: 2

Descripción y causa raíz. Un respaldo `transparencia.php.bak` permaneció dentro del document root y se sirve como texto plano (el servidor no interpreta `.bak`), revelando el código fuente PHP, incluida la variable `$releaseValidation = 'UPSLP_CNOIV-OLD-MEMORIES-04'`. El propio archivo advierte que "no debía permanecer dentro del document root". El control ausente es la exclusión de respaldos del webroot y el bloqueo de extensiones.

Comprobación. Solicitar `transparencia.php.bak` → se descarga el fuente → marcador en `$releaseValidation`.

Impacto. Divulgación de código fuente y posibles secretos; facilita el análisis de otras vulnerabilidades.

Mitigación. Eliminar respaldos del webroot; bloquear `.bak/.old/~` en el servidor; controles de despliegue que impidan dejar copias.

Bandera: `UPSLP_CNOIV-OLD-MEMORIES-04`

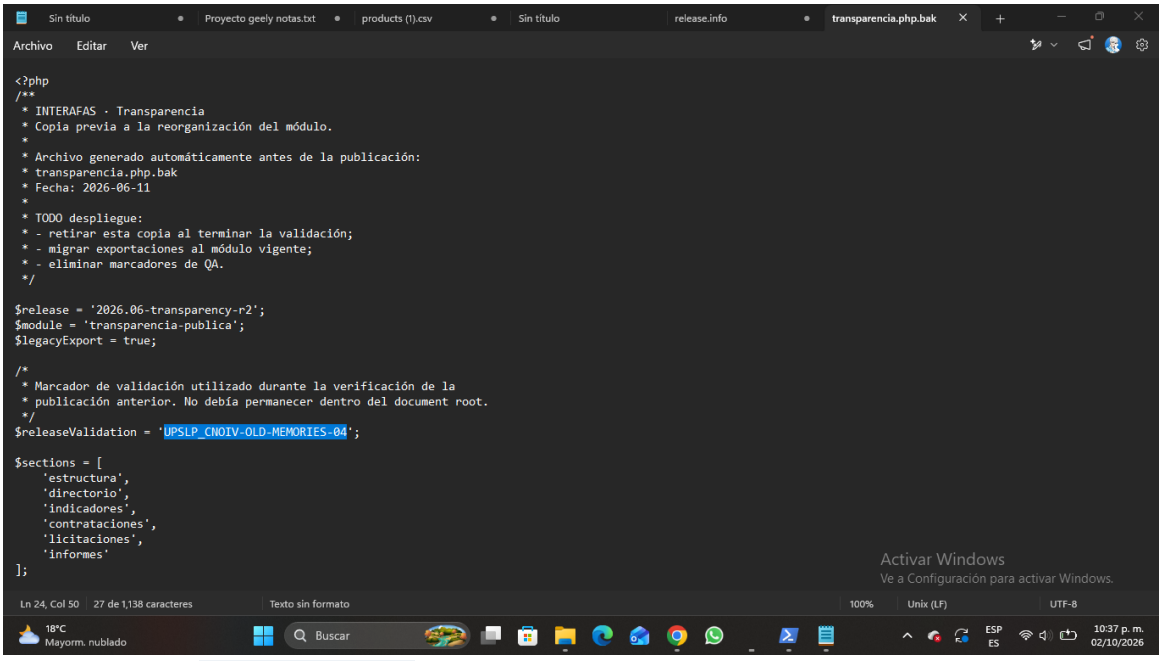


Figura 4. `transparencia.php.bak` *servido como texto; el marcador de validación queda a la vista (reto 04).*

05 TOO-MUCH-INFO — Divulgación de información por errores

MEDIA

Componente: `exportar.php?tipo=` · Categoría: Información · CWE: CWE-209 / CWE-489 · Peso: 2

Descripción y causa raíz. `exportar.php?tipo=100` provoca una excepción no controlada (`UnhandledMatchError`) con DEBUG activo en producción, mostrando la traza: ruta `/var/www/html/exportar.php:23`, módulo, entorno, el servicio de BD `db:3306` / schema `interafas` y Build validation: `UPSLP_CNOIV-TOO-MUCH-INFO-05`. El control ausente es el manejo seguro de errores y la desactivación de depuración.

Comprobación. Solicitar `exportar.php?tipo=100` (valor fuera de los casos previstos) → página de error con DEBUG → marcador en "Build validation".

Impacto. Divulgación de rutas internas, pila de ejecución, servicio y esquema de base de datos; insumo de reconocimiento.

Mitigación. Desactivar `display_errors`/DEBUG en producción; páginas de error genéricas; registrar las excepciones sólo internamente.

Bandera: `UPSLP_CNOIV-TOO-MUCH-INFO-05`

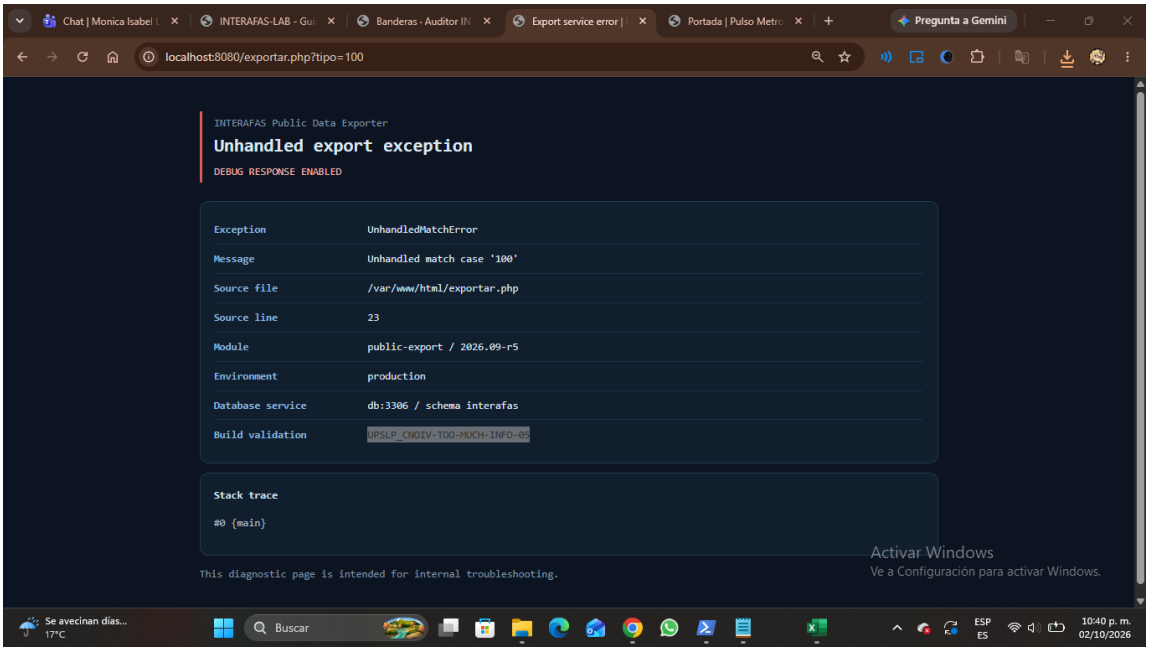


Figura 5. *Página de error con DEBUG activo: expone rutas, BD y el marcador del reto 05.*

06 WRONG-ROLE — Control de acceso por rol deficiente

ALTA

Componente: `gestion-proveedores.php` (cookie `portal_role`) · Categoría: Autorización · CWE: CWE-602 / CWE-639 · Peso: 2

Descripción y causa raíz. `gestion-proveedores.php` ejecuta una función administrativa confiando en un dato de rol controlado por el cliente (cookie `portal_role`). Estableciendo `portal_role=procurement_admin`, una sesión ciudadana logra "Escalamiento vertical confirmado". El control ausente es la autorización del lado del servidor basada en la sesión, no en datos manipulables del cliente.

Comprobación. Con la cuenta ciudadana, editar/crear la cookie `portal_role=procurement_admin` (DevTools → Aplicación → Cookies) y ejecutar la acción administrativa en `gestion-proveedores.php`.

Impacto. Escalamiento de privilegios a funciones administrativas (integridad y confidencialidad).

Mitigación. Derivar el rol del servidor (sesión/BD), nunca de cookies; verificar autorización por acción; firmar/cifrar los atributos de sesión.

Bandera: `UPSLP_CNOIV-WRONG-ROLE-06`

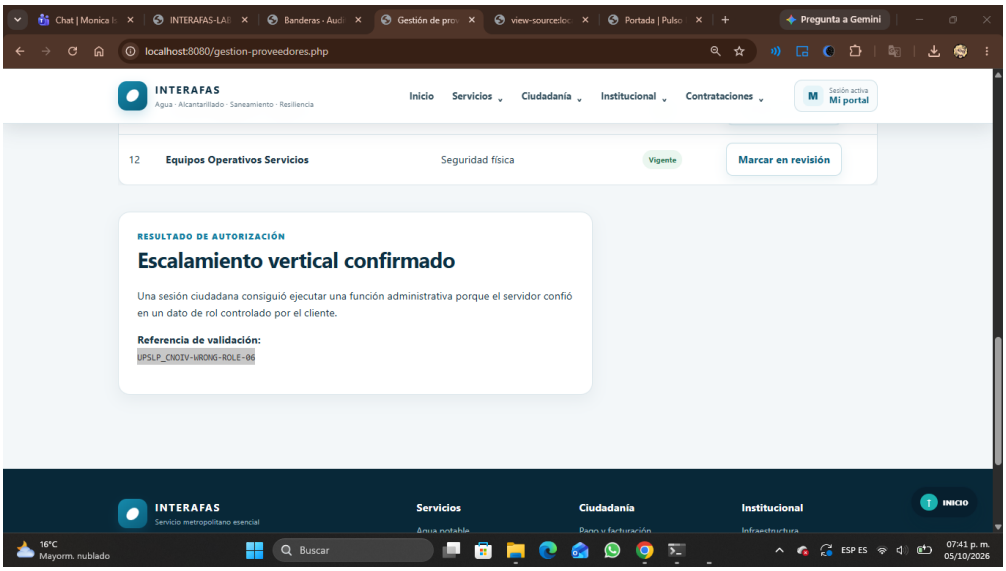


Figura 6. *"Escalamiento vertical confirmado" al confiar el servidor en un rol controlado por el cliente (reto 06).*

07 SILENT-ANSWER — SQL Injection ciega por inferencia

ALTA

Componente: `validar-referencia.php?ref=` · Categoría: Inyección · CWE: CWE-89 · Peso: 4

Descripción y causa raíz. El parámetro `ref` se concatena en una consulta SQL sin parametrizar. No devuelve datos directamente, pero la respuesta cambia según una condición booleana (oráculo ciego). El control ausente son las consultas parametrizadas (prepared statements).

Comprobación. Oráculo diferencial para cancelar el eco de entrada: `ref=z' OR (<cond>) AND '1'='1` vs `'1'='2`; extracción con `SUBSTRING`/`ASCII` e `information_schema` por búsqueda binaria del campo `verificacion_token` en la tabla `portal_validation_meta`.

Impacto. Lectura no autorizada de la base de datos (confidencialidad), con potencial de compromiso total del esquema.

Mitigación. Prepared statements/ORM parametrizado; validación de entrada; cuenta de BD con privilegio mínimo; WAF como defensa en profundidad.

Bandera: `UPSLP_CNOIV-SILENT-ANSWER-07`

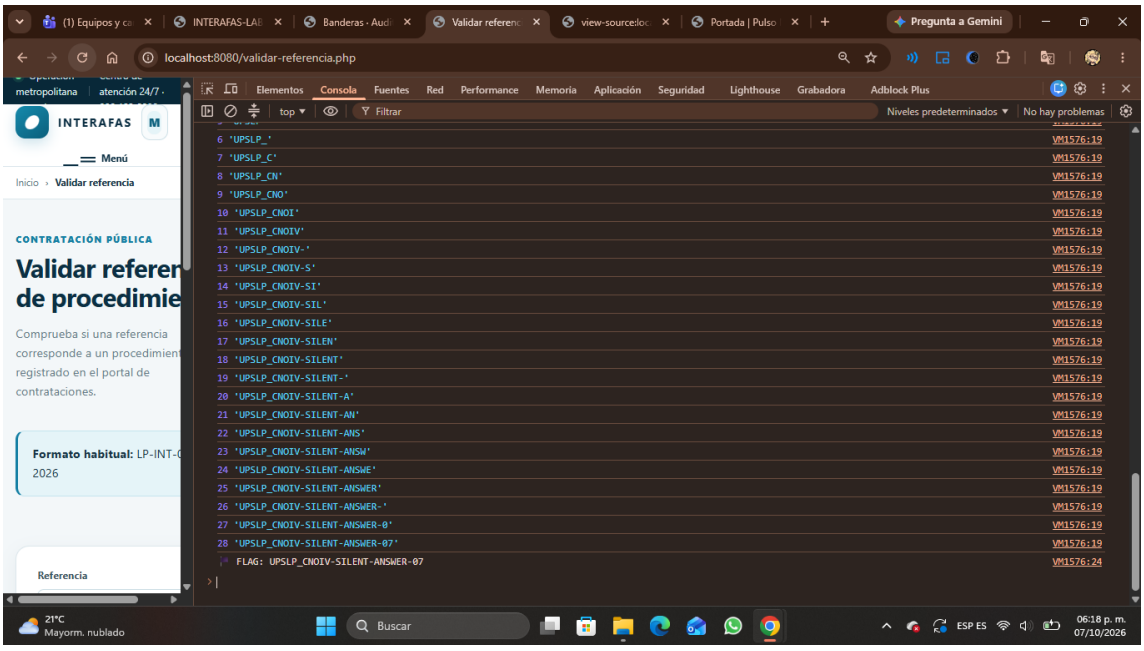


Figura 7. *Extracción por inferencia (búsqueda binaria carácter a carácter) que reconstruye y confirma en consola la bandera del reto 07.*

08 STORED-WORDS — Entrada persistente insegura (Stored XSS) ALTA

Componente: Descripción de reporte ciudadano · Categoría: Cliente · CWE: CWE-79 · Peso: 3

Descripción y causa raíz. La descripción de un reporte se almacena y luego se inserta en el HTML sin codificar la salida, permitiendo la ejecución de HTML/JavaScript almacenado a quien visualice el reporte. El control ausente es la codificación contextual de salida (output encoding) y una CSP.

Comprobación. Crear/editar un reporte con una carga tipo `<script>…</script>` en el campo descripción; al renderizarse la vista se ejecuta el script (respuesta con título `XSS_OK`) y se obtiene la bandera.

Impacto. Ejecución de script en el navegador de otros usuarios/operadores: robo de sesión, acciones en su nombre, difusión del ataque.

Mitigación. Codificar la salida según contexto (HTML/atributo/JS); Content-Security-Policy estricta; sanitización de entrada; cookies `HttpOnly`.

Bandera: `UPSLP_CNOIV-STORED-WORDS-08`

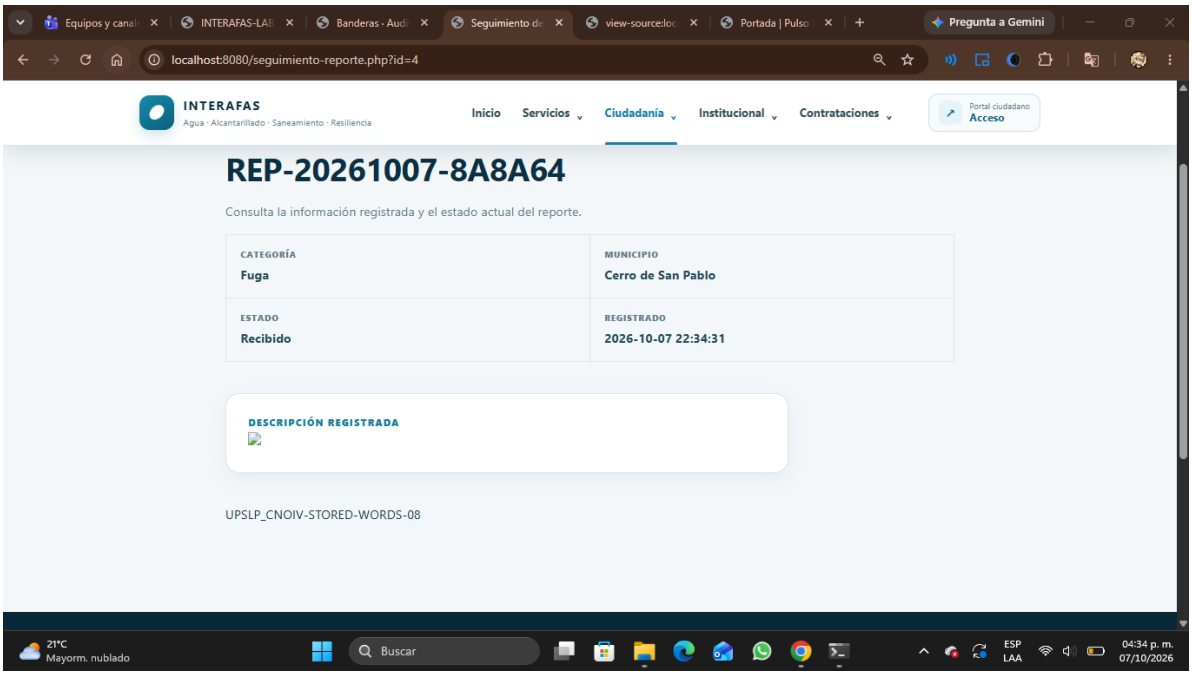


Figura 8. *El reporte almacenado se renderiza sin codificar la salida; la bandera del reto 08 queda en la vista del reporte.*

09 TOO-DEEP — Path traversal ALTA

Componente: `descargar-documento.php?file=` · Categoría: Archivos · CWE: CWE-22 · Peso: 3

Descripción y causa raíz. El parámetro `file` se concatena a `assets/docs/citizen` sin normalizar ni validar secuencias `../`. Con `../../../../../../../etc/motd` se leyó un archivo fuera del directorio autorizado. El control ausente es la canonicalización y validación de la ruta final contra un directorio base permitido.

Comprobación. `descargar-documento.php?file=../../../../../../../etc/motd` → el servidor devuelve el archivo del sistema (contenía el marcador).

Impacto. Lectura arbitraria de archivos del servidor (confidencialidad); habilita directamente el hallazgo 10.

Mitigación. Canonicalizar la ruta y verificar que quede dentro del directorio base; allow-list de nombres; evitar rutas de archivo controladas por el usuario.

Bandera: `UPSLP_CNOIV-TOO-DEEP-09`

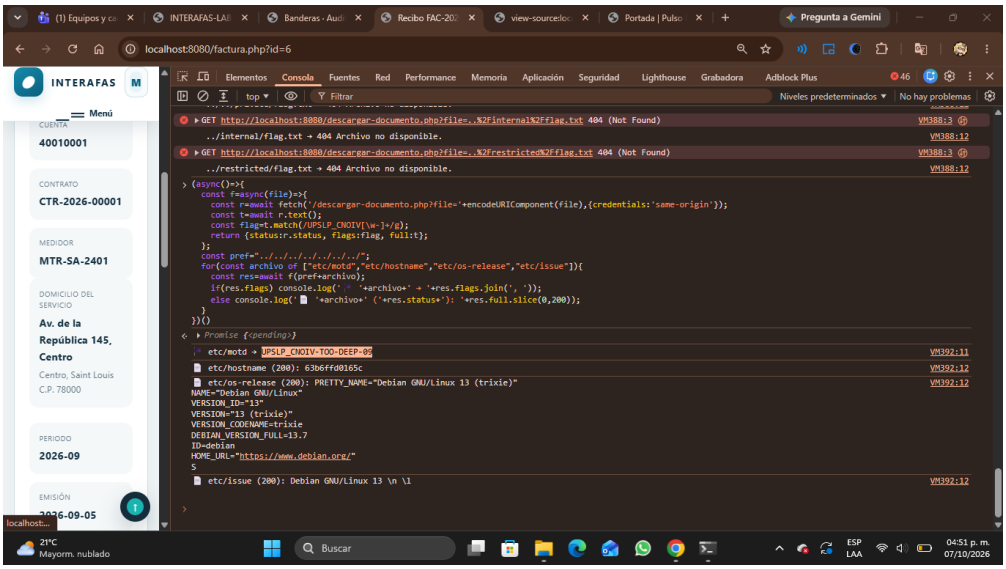


Figura 9. *Path traversal en* `descargar-documento.php` *(…/etc/motd) que devuelve la bandera del reto 09.*

10 WHO-ARE-YOU — Gestión débil de sesión

ALTA

Componente: `includes/config.php` (leído vía traversal del reto 09) · Categoría: Sesión · CWE: CWE-522 / CWE-200 · Peso: 3

Descripción y causa raíz. Aprovechando el path traversal (09) se leyó `includes/config.php`, exponiendo la configuración de sesión y secretos de la aplicación, donde se localizó el marcador. Es posible porque los secretos de sesión residen en archivos legibles mediante la lectura arbitraria y la gestión de sesión depende de ese material. El control ausente es la protección de secretos y una gestión de sesión robusta.

Comprobación. Usar el traversal de 09 apuntando a `…/includes/config.php` → lectura de los parámetros de sesión/secreto que contienen la bandera.

Impacto. Compromiso de la gestión de sesión (posible falsificación/fijación) y suplantación de identidad.

Mitigación. Corregir el traversal (09); mover secretos fuera del webroot a variables de entorno gestionadas y rotarlos; identificadores de sesión robustos con `HttpOnly`/`Secure` y regeneración al autenticar.

Bandera: `UPSLP_CNOIV-WHO-ARE-YOU-10`

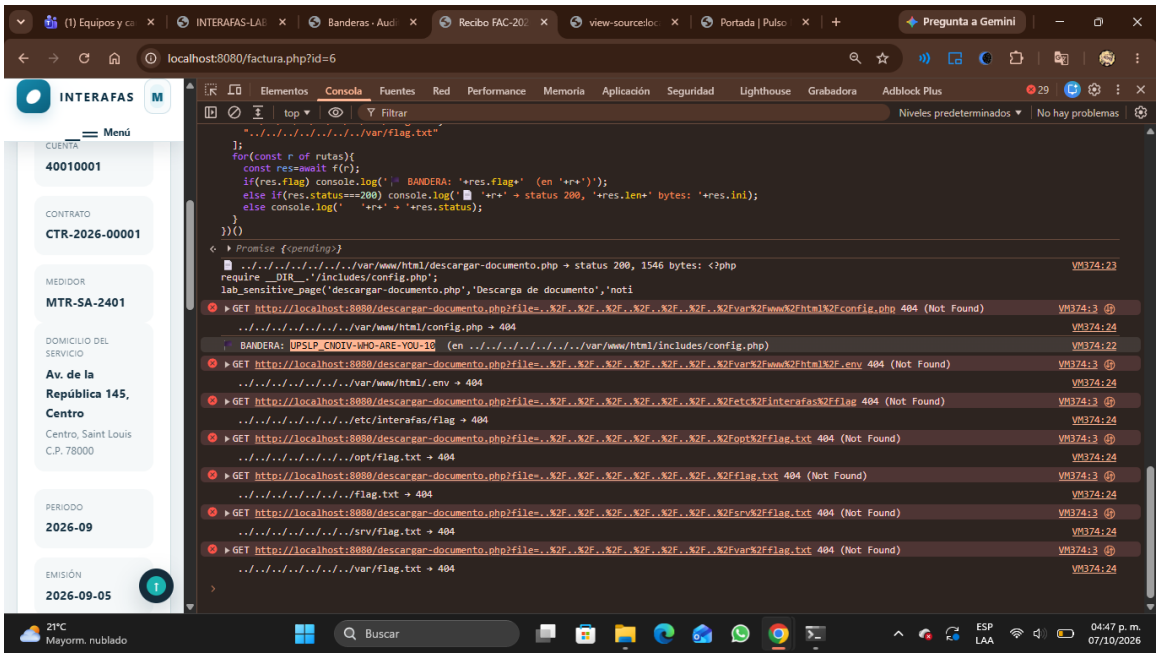


Figura 10. *Lectura de* `includes/config.php` *mediante el mismo traversal; la bandera del reto 10 queda expuesta en la consola.*

11 HIDDEN-HISTORY — Endpoint no documentado

MEDIA

Componente: `/api/account-context.php` → `/api/service-history.php?account=` · Categoría: API · CWE: CWE-200 · Peso: 3

Descripción y causa raíz. `/api/account-context.php` devuelve un JSON que incluye `links.history` apuntando a `/api/service-history.php?account=40010001`, un endpoint no documentado. Al consultarlo, la bandera llega en el encabezado `x-interafas-validation`. El control ausente es el inventario y control de la superficie de API (shadow API).

Comprobación. `GET /api/account-context.php` → leer `links.history` → `GET /api/service-history.php?account=40010001` → bandera en el header.

Impacto. Descubrimiento de superficie de API no documentada; base para el hallazgo 12.

Mitigación. Inventario y gobierno de endpoints; no exponer enlaces internos; autenticación/autorización uniforme en toda la API.

Bandera: `UPSLP_CNOIV-HIDDEN-HISTORY-11`

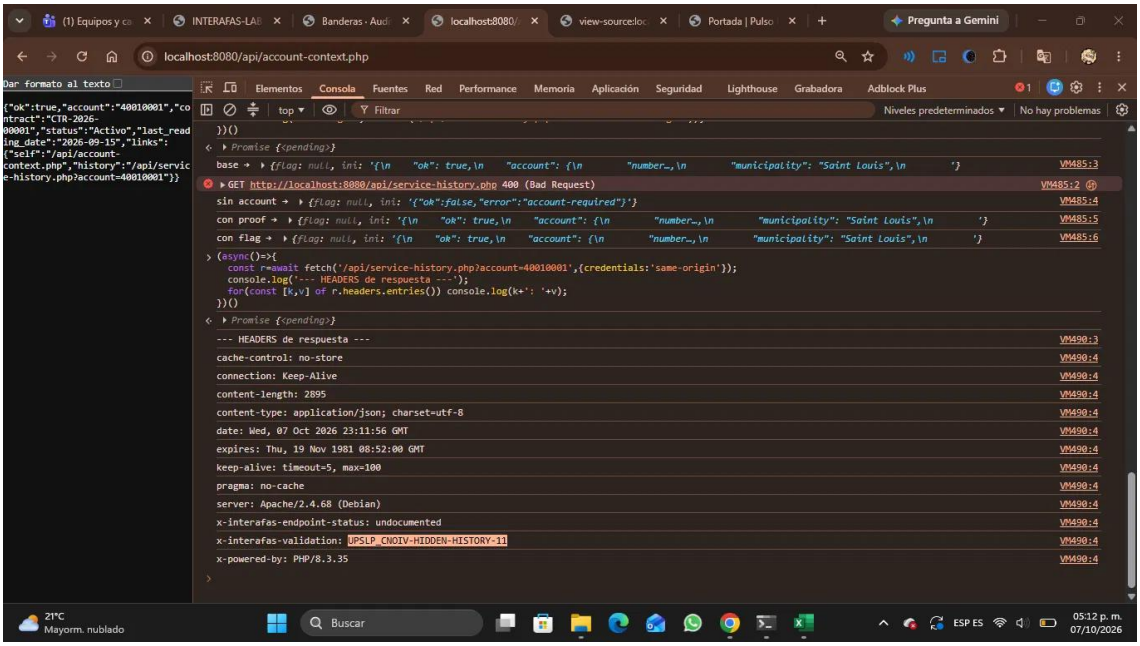


Figura 11. `account-context.php` *revela el endpoint no documentado* `links.history` → `/api/service-history.php?account=40010001` *(reto 11); la bandera se entrega en el encabezado* `X-Interafas-Validation` *de ese endpoint.*

12 SECOND-ACCOUNT — Autorización de objetos deficiente en API (BOLA)

ALTA

Componente: `/api/service-history.php?account=` · Categoría: API / Autorización · CWE: CWE-285 (API1:2023 BOLA) · Peso: 4

Descripción y causa raíz. El endpoint entrega el historial de la cuenta indicada en `account` sin verificar que pertenezca al solicitante. Cambiando el valor a otras cuentas válidas (p. ej. `40010002`) se accede a datos de terceros (Broken Object Level Authorization). El control ausente es la autorización a nivel de objeto en la API.

Comprobación. `GET /api/service-history.php?account=40010002` (cuenta ajena) → devuelve datos de otra cuenta; comparación con `40010001`.

Impacto. Acceso masivo no autorizado a datos de clientes (confidencialidad); enumerable a gran escala.

Mitigación. Validar la propiedad de `account` contra la sesión en el servidor; identificadores no enumerables; límites de tasa y registro.

Bandera: `UPSLP_CNOIV-SECOND-ACCOUNT-12`

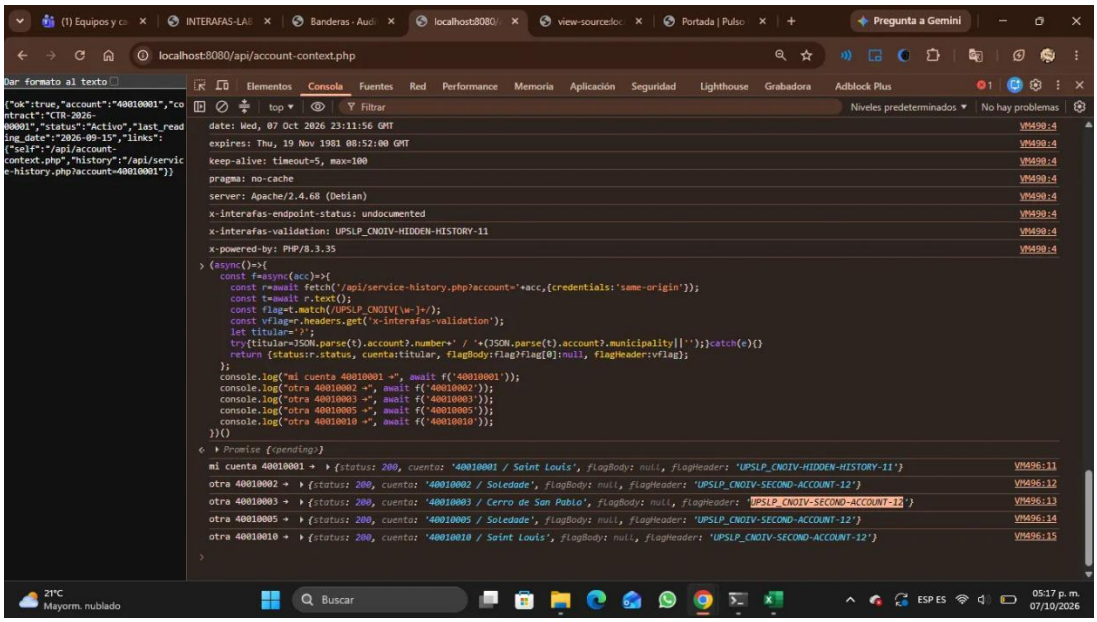


Figura 12. *Enumeración de cuentas ajenas (40010002–40010012) vía `service-history.php` (BOLA, reto 12); la bandera llega en el encabezado `X-Interafas-Validation`.*

13 PAYMENT-PATH — Abuso de lógica de negocio en flujo de pago

ALTA

Componente: Flujo de pago (`factura_id` / `cuenta` / `monto`) · Categoría: Lógica de negocio · CWE: CWE-840 / CWE-639 · Peso: 4

Descripción y causa raíz. El flujo de pago procesa un `factura_id` y una `cuenta` enviados en el POST sin verificar titularidad. Enviando la factura y la cuenta de un tercero con `monto=1`, la operación se procesó sobre un recibo ajeno pendiente y reveló la bandera en el encabezado `x-interafas-validation`. El control ausente es la verificación de titularidad y la integridad del monto del lado del servidor.

Comprobación. POST al endpoint de pago con `factura_id=12`, `cuenta=40010002` (tercero) y `monto=1` → operación aceptada; bandera en el header.

Impacto. Manipulación de pagos sobre cuentas ajenas; fraude (integridad, operación y confidencialidad).

Mitigación. Validar que la factura pertenezca a la cuenta del usuario; calcular el monto en el servidor (no confiar en el cliente); controles anti-manipulación y auditoría de transacciones.

Bandera: `UPSLP_CNOIV-PAYMENT-PATH-13`

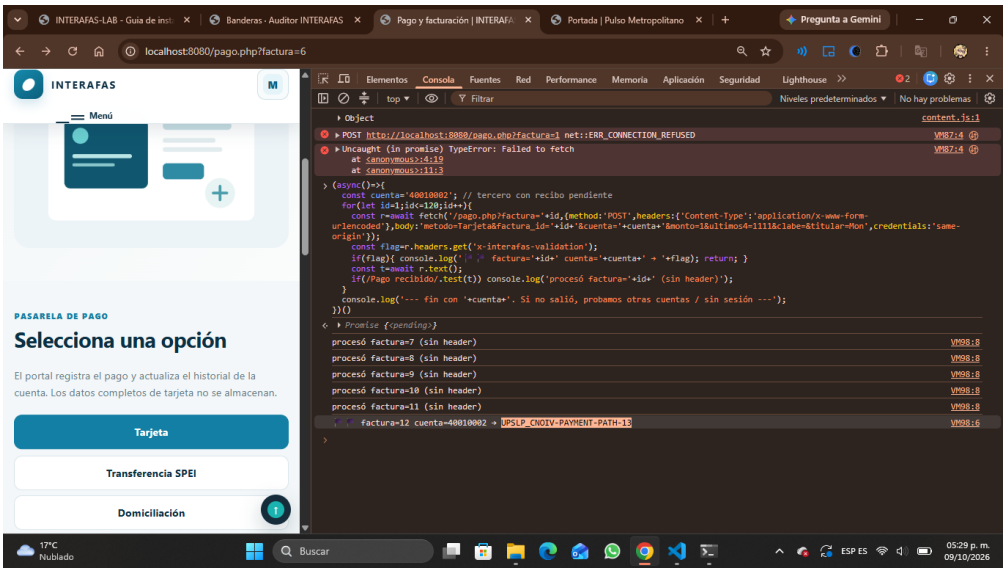


Figura 13. *Pago procesado sobre la factura y la cuenta de un tercero (`factura=12` · `cuenta=40010002`); la consola imprime la bandera del reto 13.*

14 TRUSTED-SUPPLIER — Control deficiente de relación proveedor-contrato

ALTA

Componente: `validar-vinculo-contractual.php?contract_id=&provider_id=` · Categoría: Lógica de negocio · CWE: CWE-840 / CWE-285 · Peso: 4

Descripción y causa raíz. El servicio acepta una combinación `contract_id/provider_id` (“Relación inconsistente aceptada”) sin comprobar que el contrato esté asociado al proveedor indicado ni la autorización del solicitante. Con `contract_id=1&provider_id=100` se valida un vínculo inexistente. El control ausente es la validación de la relación entre objetos y la autorización.

Comprobación. `GET validar-vinculo-contractual.php?contract_id=1&provider_id=100` → “Relación inconsistente aceptada” + referencia de validación.

Impacto. Validación indebida de vínculos contractuales; abuso de confianza en el proceso de contrataciones (integridad / fraude).

Mitigación. Verificar en el servidor la asociación real contrato↔proveedor; aplicar autorización; rechazar combinaciones inconsistentes.

Bandera: `UPSLP_CNOIV-TRUSTED-SUPPLIER-14`

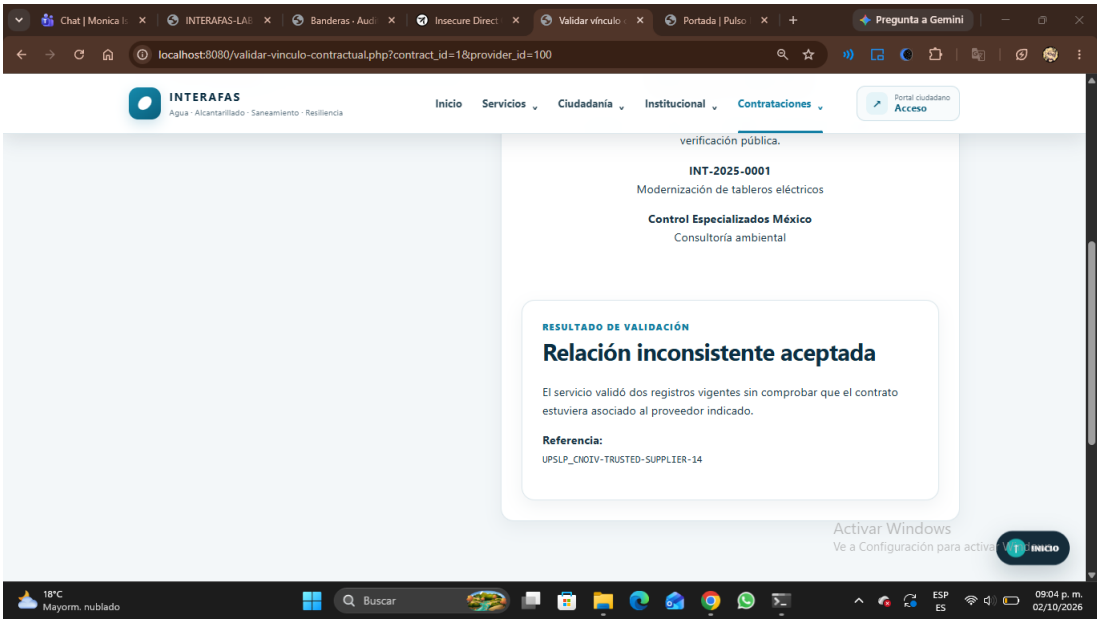


Figura 14. *“Relación inconsistente aceptada” en* `validar-vinculo-contractual.php` *con la referencia del reto 14.*

15 BEHIND-THE-DESK — Descubrimiento de configuración / arquitectura interna

MEDIA

Componente: `infrastructure-status.php` · Categoría: Arquitectura · CWE: CWE-200 · Peso: 4

Descripción y causa raíz. `infrastructure-status.php` expone, en su cuerpo y en el header `x-interafas-validation`, metadatos internos que la interfaz oculta: el segmento `10.40.20.0/24`, el componente `ot-sim`, el activo `RTU-GW-07` y la ruta `/operations/gateway.php`. El control ausente es no divulgar la arquitectura/segmentación interna.

Comprobación. `GET /infrastructure-status.php` → revisar el cuerpo y el encabezado `x-interafas-validation`.

Impacto. Entrega el mapa de la red OT y las rutas de pivote: insumo clave de la cadena IT→OT.

Mitigación. No exponer metadatos de infraestructura; autenticar endpoints de estado; ocultar detalles internos y segmentar realmente.

Bandera: `UPSLP_CNOIV-BEHIND-THE-DESK-15`

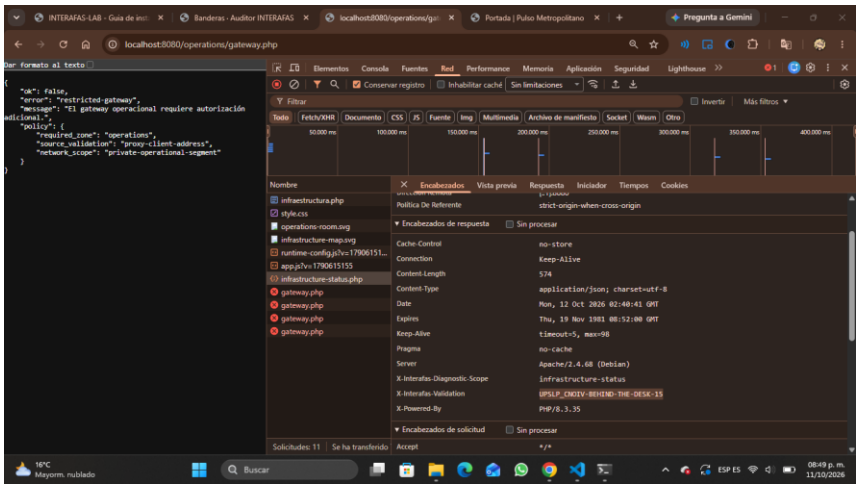


Figura 15. `infrastructure-status.php`*: el encabezado* `X-Interafas-Validation` *expone la bandera del reto 15 junto con metadatos internos (segmento OT, RTU-GW-07, ruta del gateway).*

16 BEYOND-THE-WEB — Acceso indebido al gateway operacional

ALTA

Componente: `/operations/gateway.php` (`X-Forwarded-For`) · Categoría: IT → OT · CWE: CWE-290 / CWE-348 · Peso: 4

Descripción y causa raíz. `/operations/gateway.php` confía en el encabezado `X-Forwarded-For` para validar el origen. Enviando `X-Forwarded-For: 10.40.20.10` (segmento OT revelado en 15) se cruza la frontera IT/OT y se revela la entrada operativa `/operations/login.php`. El control ausente es no basar decisiones de seguridad en cabeceras controlables por el cliente ni sustituir la segmentación real.

Comprobación. `GET /operations/gateway.php` con el header `X-Forwarded-For: 10.40.20.10` → acceso y descubrimiento de `/operations/login.php`.

Impacto. Cruce del límite IT→OT y acceso a la superficie operacional desde la red corporativa.

Mitigación. No usar `X-Forwarded-For` para autorización; validar el origen a nivel de red; firewall/segmentación efectiva entre IT y OT; autenticación fuerte en el gateway.

Bandera: `UPSLP_CNOIV-BEYOND-THE-WEB-16`

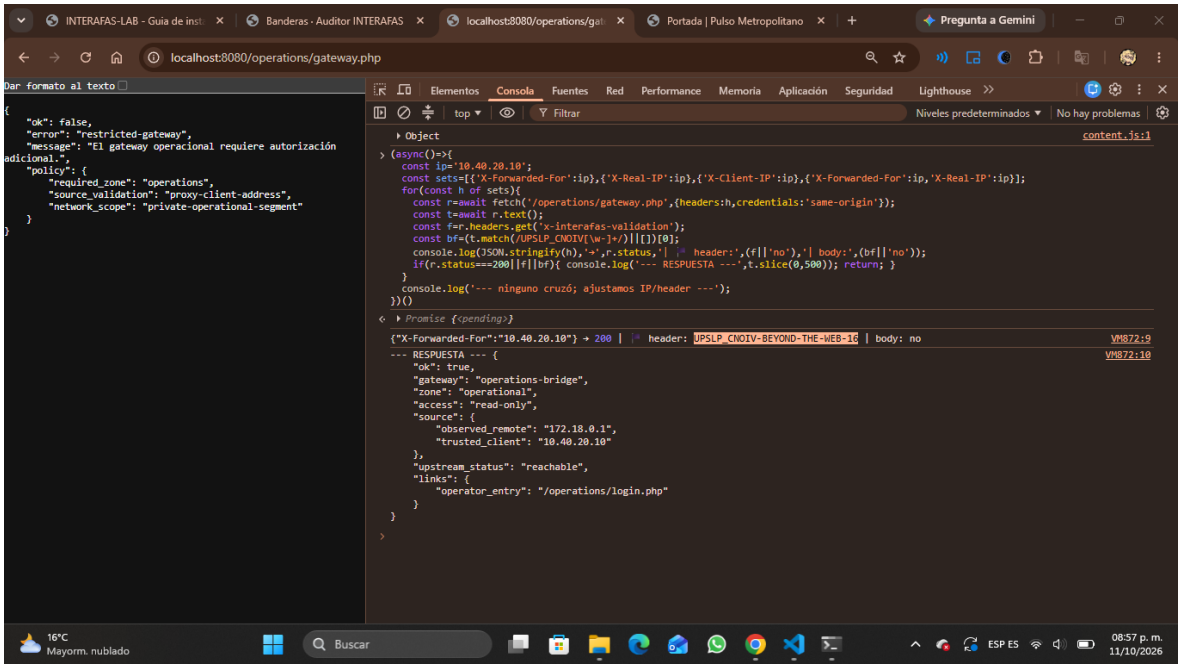


Figura 16. `X-Forwarded-For: 10.40.20.10` *en* `gateway.php`*: la bandera del reto 16 llega en el encabezado y se revela* `operator_entry: /operations/login.php`.

17 EYES-ON-THE-PLANT — Acceso no autorizado a la vista HMI

ALTA

Componente: `/operations/telemetry.php` · Categoría: OT simulado · CWE: CWE-306 · Peso: 4

Descripción y causa raíz. `/operations/telemetry.php` expone sin sesión de operador el estado completo del proceso y datos de firmware (confirmado por el header `X-Interafas-Operational-Session: missing`), mientras `/operations/login.php` sí exige autenticación. El control ausente es el control de acceso uniforme en todos los endpoints OT (ausencia de autenticación en una vista sensible).

Comprobación. `GET /operations/telemetry.php` sin sesión → devuelve la telemetría completa; header `X-Interafas-Operational-Session: missing`.

Impacto. Visibilidad no autorizada del proceso (confidencialidad operacional y reconocimiento OT).

Mitigación. Exigir sesión de operador en todos los endpoints OT; principio de denegación por defecto; registro y alerta de accesos sin sesión.

Bandera: `UPSLP_CNOIV-EYES-ON-THE-PLANT-17`

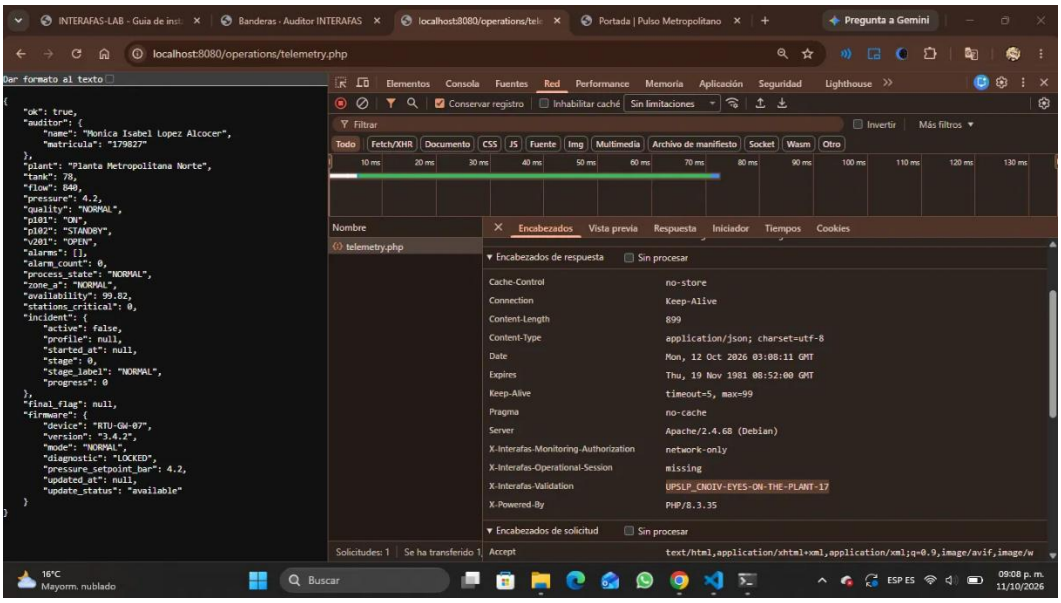


Figura 17. `telemetry.php` *devuelve el estado completo del proceso sin sesión de operador (reto 17); la bandera se entrega en el encabezado* `X-Interafas-Validation`.

18 TRUST-THE-PACKAGE — Validación defectuosa de firmware (integridad ≠ autenticidad)

CRÍTICA

Componente: `/operations/updates/install.php` · Categoría: Firmware simulado · CWE: CWE-345 / CWE-347 · ATT&CK ICS: T0857 · Peso: 5

Descripción y causa raíz. `install.php` aceptó un paquete de firmware con payload modificado y SHA-256 recalculado, sin exigir firma del emisor (`authenticity: not-verified`): verifica integridad pero no autenticidad. Además, la autenticación de soporte usa Basic con credenciales débiles (`soporte.ot:Soporte343`, hash SHA-1 crackeado). El control ausente es la verificación de firma digital del emisor y credenciales robustas.

Comprobación. Crackear el `verification_ref` SHA-1 → `Soporte343`; POST `/operations/updates/install.php` (JSON) con `Authorization: Basic base64(soporte.ot:Soporte343)`, el payload modificado y su SHA-256 → respuesta `integrity: passed`, `authenticity: not-verified` → bandera.

Impacto. Instalación de firmware/configuración no auténtica en componentes OT (integridad); habilita directamente el impacto final (20).

Mitigación. Exigir y verificar firma digital del emisor (cadena de confianza); no basar la confianza sólo en el hash de integridad; credenciales fuertes con rotación y algoritmos de hash modernos.

Bandera: `UPSLP_CNOIV-TRUST-THE-PACKAGE-18`

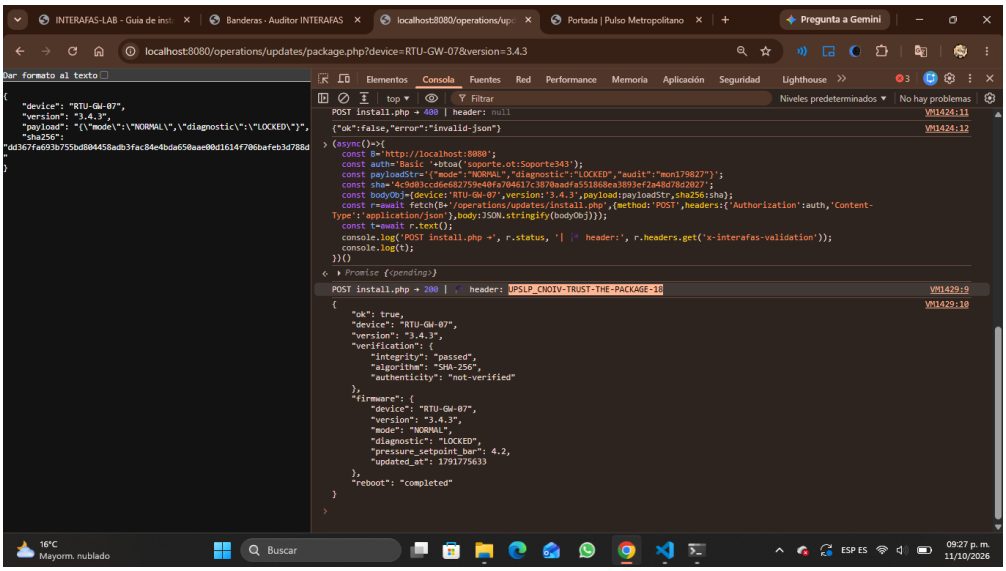


Figura 18. `install.php` *acepta el paquete con SHA-256 recalculado (*`integrity: passed` · `authenticity: not-verified`*); la consola imprime la bandera del reto 18.*

19 CHAIN-REACTION — Encadenamiento de dependencias IT → OT

CRÍTICA

Componente: `/operations/asset-context.php` · Categoría: Cadena de ataque · CWE: CWE-285 / CWE-639 · ATT&CK ICS: T0840 · Peso: 5

Descripción y causa raíz. `asset-context.php` expone la cadena de dependencias con `server_enforced_dependency_boundary=false`: el servidor no aplica el límite de autorización en la enumeración. Siguiendo el campo `expected_next` se recorren 6 saltos hasta `depth 6/6 (complete=true)` y la bandera llega en el header `X-Interafas-Validation`. El control ausente es la aplicación del límite de dependencias/autorización por rol.

Comprobación. Iterar `GET /operations/asset-context.php?asset=<expected_next>` desde `RTU-GW-07`: `RTU-GW-07 → PLC-SL-01 → P-SL-101 → HDR-SL-01 → V-SL-201 → ZONE-SL-A` hasta `complete=true`.

Impacto. Enumeración completa de la cadena de dependencias OT desde una posición IT; reconocimiento profundo que habilita el cargador de firmware y el impacto final.

Mitigación. Aplicar en el servidor el límite de dependencias/autorización por rol; negar la travesía más allá del alcance permitido.

Bandera: `UPSLP_CNOIV-CHAIN-REACTION-19`

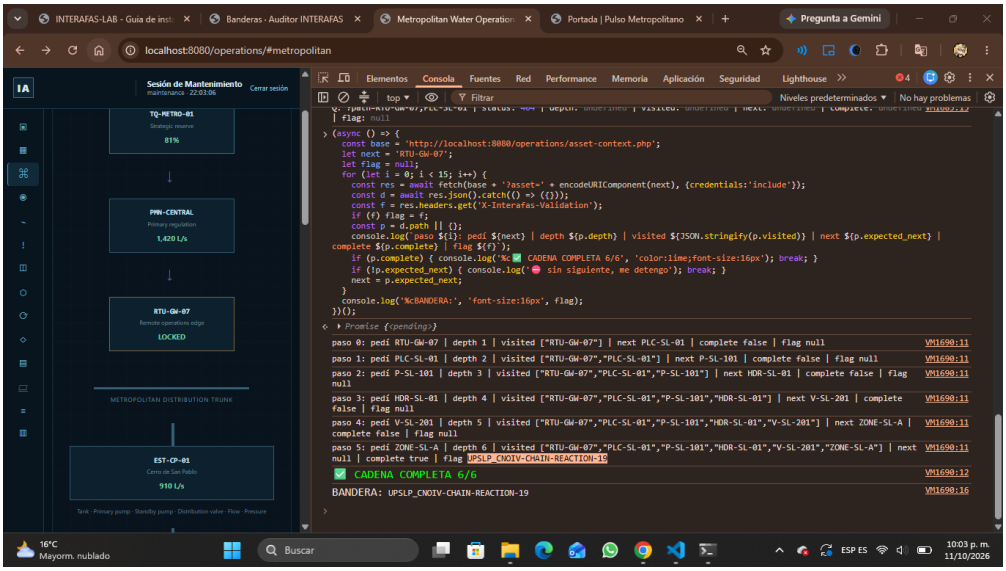


Figura 19. *Enumeración de los 6 saltos de dependencias hasta* `complete=true (6/6)`*; la bandera del reto 19 en el encabezado.*

20 NOW-YOU-CONTROL — Impacto operacional final (estado catastrófico) CRÍTICA

Componente: `/operations/firmware.php` → install (`pressure_setpoint_bar`) · Categoría: OT simulado · CWE: CWE-20 / CWE-345 · ATT&CK ICS: T0836 (Modify Parameter) · Peso: 5

Descripción y causa raíz. El cargador de firmware (habilitado tras validar la cadena 19) acepta una configuración JSON sin verificar firma/autenticidad ni validar el rango del parámetro `pressure_setpoint_bar`. El control ausente es la validación de rangos operacionales seguros (y la autenticidad del paquete).

Comprobación. En `/operations/firmware.php`, editar el JSON del backup cambiando únicamente `pressure_setpoint_bar` de 4.2 a 9.9 bar (rango seguro 4.1–4.5) y pulsar "Validar e instalar" → cascada de proceso de 5 etapas → `CATASTROPHIC STATE` (~6 842 alarmas, disponibilidad 4.1%) → bandera en el encabezado.

Impacto. Pérdida total de control del proceso: disponibilidad y seguridad física (simulada) de infraestructura crítica de agua. Es el desenlace de toda la cadena.

Mitigación. Validar en el servidor los rangos operacionales seguros; firma/autenticidad del firmware; interlocks y límites físicos/lógicos; separación de funciones y aprobación para cambios de setpoint; monitoreo con parada segura ("trip").

Bandera: `UPSLP_CNOIV-NOW-YOU-CONTROL-20`

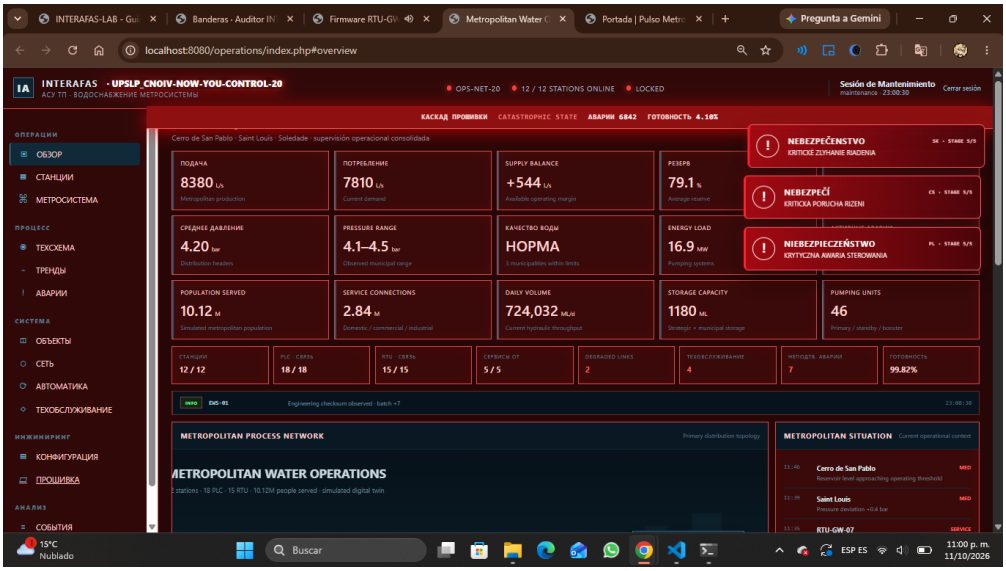


Figura 20. `CATASTROPHIC STATE` *tras el cambio de setpoint; la bandera del reto 20 aparece en la cabecera del HMI.*

5. Impacto y riesgo

Los hallazgos afectan a los tres pilares de seguridad y, de forma distintiva, a la operación y a la infraestructura crítica simulada. La siguiente tabla resume la afectación por dimensión.

Dimensión	Hallazgos principales	Consecuencia
Confidencialidad	01, 02, 03, 04, 05, 07, 09, 10, 11, 12, 15	Fuga de secretos, datos personales, código fuente, contenido de la base de datos y arquitectura interna.
Integridad	06, 08, 13, 14, 18, 20	Escalamiento de privilegios, inyección de script, manipulación de pagos y contratos, y firmware/setpoint alterados.
Disponibilidad	19 (habilitador), 20	Estado catastrófico del proceso: ~6 842 alarmas y disponibilidad del 4.1%.
Operación / Infraestructura crítica	16, 17, 18, 19, 20	Cruce del límite IT→OT, visibilidad y control no autorizados del proceso de agua, hasta la pérdida total de control.

Riesgo principal. El riesgo más alto no es ninguna vulnerabilidad aislada, sino su encadenamiento: una fuga de arquitectura "de severidad media" (15) termina habilitando, junto con la confianza mal ubicada en cabeceras (16) y en paquetes no

firmados (18), un impacto físico simulado sobre infraestructura crítica (20). En un entorno real, este patrón corresponde a un incidente de seguridad OT con potencial de afectación a la continuidad del servicio de agua.

6. Mitigaciones

Cada hallazgo incluye su mitigación específica en la sección 4. A nivel consolidado, se recomiendan las siguientes acciones prioritarias, agrupadas por causa raíz común.

Prioridad 1 — Frontera y entorno OT (hallazgos 16–20)

- Exigir firma digital del emisor en todo paquete de firmware/configuración y verificarla antes de instalar; no confiar en el hash de integridad como prueba de autenticidad.
- Validar en el servidor los rangos operacionales seguros de cada parámetro (p. ej. `pressure_setpoint_bar`) e incorporar interlocks y parada segura ante valores fuera de rango.
- No usar `X-Forwarded-For` ni otras cabeceras del cliente para autorización; aplicar segmentación efectiva IT/OT y autenticación fuerte en el gateway.
- Exigir sesión de operador en todos los endpoints OT (telemetría, asset-context) y aplicar el límite de dependencias/autorización del lado del servidor.

Prioridad 2 — Autorización (03, 06, 11, 12, 13, 14)

- Implementar autorización a nivel de objeto y de función en el servidor: validar la propiedad de cada recurso (expedientes, cuentas, facturas, contratos) contra la sesión.
- Derivar el rol exclusivamente de la sesión del servidor; nunca de cookies o datos del cliente.
- Gobernar la superficie de API (inventario, denegación por defecto, sin enlaces internos expuestos).

Prioridad 3 — Entradas, salidas y manejo de errores (07, 08, 09, 10)

- Consultas parametrizadas para eliminar la inyección SQL; privilegio mínimo en la cuenta de BD.
- Codificación de salida contextual y CSP estricta para neutralizar el XSS almacenado.
- Canonicalizar y validar rutas (allow-list) para cerrar el path traversal y la lectura de `config.php`; mover secretos fuera del webroot y rotarlos.

Prioridad 4 — Exposición de información (01, 02, 04, 05, 15)

- Retirar artefactos de despliegue, respaldos (`.bak`) y manifiestos del document root; bloquear esas extensiones en el servidor.
- Desactivar depuración en producción y usar páginas de error genéricas.
- No exponer metadatos de infraestructura/arquitectura; autenticar los endpoints de estado.

7. Cadena de ataque

Los 20 hallazgos no son independientes: forman una progresión coherente desde el reconocimiento externo hasta el impacto físico simulado en OT. Esta es la trayectoria del incidente.

Fase	Hallazgos	Qué habilita hacia la siguiente fase
1. Reconocimiento y exposición	01, 02, 04, 05, 15	Se recolectan tokens, código fuente y metadatos; sobre todo, 15 revela la arquitectura OT (segmento `10.40.20.0/24`, `RTU-GW-07` y la ruta del gateway).
2. Acceso y autorización	03, 06, 11, 12	IDOR y escalamiento de rol dan acceso a datos y funciones ajenas; el descubrimiento de la API (11) habilita el BOLA (12).
3. Explotación técnica	07, 08, 09, 10	SQLi, XSS almacenado y path traversal; el traversal (09) permite leer `config.php` y comprometer la sesión (10).
4. Abuso de lógica de negocio	13, 14	Pagos y vínculos contractuales ejecutados sobre objetos ajenos, demostrando falta de validación de titularidad/relación.

Fase	Hallazgos	Qué habilita hacia la siguiente fase
5. Cruce IT → OT	16, 17	La arquitectura de 15 + el spoofing de `X-Forwarded-For` (16) cruzan a OT; la telemetría sin sesión (17) da visibilidad del proceso.
6. Compromiso OT y impacto	18, 19, 20	Firmware sin autenticidad (18) + enumeración de la cadena (19) habilitan el cargador que, sin validar rangos, lleva el proceso al estado catastrófico (20).

Lectura de la cadena. El caso demuestra el patrón clásico de un ataque a infraestructura crítica: vulnerabilidades individualmente "menores" de exposición y confianza mal ubicada se encadenan para saltar de la red corporativa (IT) al entorno de control (OT) y, finalmente, alterar un parámetro físico del proceso. Romper cualquier eslabón de la fase 5–6 (segmentación real, firmware firmado, validación de rangos) habría impedido el desenlace.

8. Conclusiones

Se identificaron y comprobaron las 20 vulnerabilidades del entorno INTERAFAS-LAB, cada una validada con la obtención de su bandera. El ejercicio confirma que la seguridad del entorno falla de manera sistémica y no puntual: los mismos errores de diseño —confiar en datos del cliente, no verificar propiedad/relación de objetos, y verificar integridad pero no autenticidad— se repiten en distintos módulos y escalan de severidad conforme se avanza hacia el entorno operacional.

Desde mi análisis, el hallazgo decisivo no es el de mayor peso individual, sino la continuidad de la cadena: una fuga de arquitectura clasificada como media (15) es la que, encadenada con la confianza en cabeceras (16) y en firmware no firmado (18), hace posible el impacto catastrófico (20). Por ello, la remediación debe priorizar los límites de confianza — segmentación IT/OT real, firma de firmware y validación de rangos operacionales— por encima de corregir vulnerabilidades de forma aislada.

Como aprendizaje, el ejercicio refuerza que la defensa de infraestructura crítica exige defensa en profundidad: la autorización del lado del servidor, el manejo correcto de entradas/salidas y la higiene de despliegue (no dejar artefactos ni respaldos expuestos) son tan importantes como los controles específicos de OT. Atender las cuatro prioridades de mitigación propuestas reduciría de forma significativa la superficie de ataque y, sobre todo, rompería la cadena que conduce al impacto final.

9. Referencias

Marcos y estándares de referencia

- OWASP — Web Security Testing Guide (WSTG) y OWASP Top 10 (2021).
- OWASP — API Security Top 10 (2023), en particular API1:2023 Broken Object Level Authorization (BOLA) (hallazgos 12, 03).
- MITRE ATT&CK for ICS — T0840 Network Connection Enumeration (19), T0857 System Firmware (18), T0836 Modify Parameter (20).
- MITRE CWE — referencias por hallazgo (CWE-22, 79, 89, 200, 209, 285, 290, 306, 345, 347, 489, 522, 530, 538, 540, 602, 639, 840).